ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

SEL-3505 Real-Time Automation Controller (field controller) · Component type: **Embedded Device (EDR) - compact field controller** · Target SL = SL 3

Where to work	Configure with **acSELerator RTAC (SEL-5033)** over TLS; the RTAC runs **SEL Blueframe OS** (hardened Linux); manage users/roles, protocols, TLS certs, and syslog in the project + web interface (HTTPS). SEL-3505 is a compact field controller (fixed-function; no app hosting).
Interfaces / ports	HTTPS **443** (web/config); acSELerator RTAC engineering over **TLS**; SSH **22** (disable if unused); DNP3 **20000** (+ Secure Authentication); Modbus **502**; IEC 61850 **102**; Syslog **514**; NTP **123**.
Notes	EDR (field controller). Confirm hardware (SEL-3505) and RTAC firmware version; apply the **SEL hardening / cybersecurity** guidance. Cross-check SEL security notifications for advisories.
How to read	Default read-only (acSELerator read-only project review, web view). Native how-to + external-tool validation + pass. Write/exploit tools = isolated env + written authorization.

Session setup & evidence handling

Do this BEFORE running any command so the evidence is complete, attributable, and protected:
1. Start a full session log first. PuTTY: Session › Logging → select **All session output** → set **Log file name** (browse to the encrypted evidence folder) → under “if the log file already exists” pick **Always append** → tick **Include header** and (Logging › Options) **Flush log frequently**; put `&Y&M&D_&T` in the name for an auto timestamp. (SecureCRT: File › Log Session; Tera Term: File › Log; macOS/Linux: `script -a <file>.log` or `ssh user@host | tee <file>.log`.)
2. Name the file to the evidence convention (one file per device): `<site>_<zone>_<assetTag>_<vendor>_<model>_<mgmtIP>_<YYYYMMDD-HHMM>_<testerInitials>.log`.
3. Disable paging so full output is captured (it resets each login): SSH console (Linux/BlueFrame): append `| cat` if a pager opens; the primary config evidence is the AcSELerator RTAC project export; capture the SSH session with PuTTY logging or `script -a <file>.log`.
4. Self-document the log - capture identity/time first: `hostname; date -u`, so the file proves what/when/who.
5. Close out: restore paging, stop the log (PuTTY closes it when the session ends), and verify the file opened/saved.
6. Protect the evidence file. It contains running-config and may hold hashes, SNMP community strings, or keys: store **only** on the encrypted assessment share, follow the project data-classification/retention policy, redact secrets before sharing, and **never** email it in cleartext. **Do not save the device password in the PuTTY/SecureCRT saved session** - authenticate interactively or via the approved password manager.

Project / config capture & evidence handling - capture the device backup + config export

Do this BEFORE working the checklist - screenshots and walking the config screens are not enough on their own. Capture the device’s own backup / project export so nothing is missed:
1. Pull the native backup / project + full config export first (read-only, before anything): the AcSELerator RTAC project database export (settings + IEC 61131 logic), the per-device / protocol connection configs and tag database, the user accounts + role mappings and account/security settings, any hosted-app / container config (SEL-3555/3350), firmware rev, and the RTAC logs + SOE (sequence-of-events) export.
2. Export the security-relevant settings: user accounts / roles / password policy, comms / port / protocol enable-disable, and any certificate / key / CIP-Security settings - as files and screenshots.
3. Collect firmware & logs: firmware / boot revision, and the event / audit / diagnostic logs and fault / alarm buffers (exports) where the device provides them.
4. Capture the device identity: nameplate (catalog + serial), firmware / hardware rev, installed modules / option cards, and slot / network address - **photograph** the device, faceplate / HIM and panel labels.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<vendor>_<model>_<fwRev>_<YYYYMMDD-HHMM>_<initials>` with the native project / backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup may hold credentials / keys - **never** email it in cleartext and follow the project retention / classification policy. Do not save device passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can’t auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user I&A	Confirm all access (web HMI, acSELerator RTAC engineering, SSH if enabled) requires authentication; **RBAC user accounts** defined; no default/shared credentials. **Test:** connect acSELerator / browse the web without credentials -> denied. **Ext. tools:** acSELerator RTAC (account review); web browser (HTTPS); Nmap; ReadOnlyEnum.	All interfaces authenticate; no anonymous/default access.	EDR + host.
SR/CR 1.2	Device & software-process I&A	Machine-to-machine over secure protocols: **DNP3 Secure Authentication (SA)**, IEC 62351/TLS for IEC 61850/engineering; confirm which links are authenticated. **Test (isolated):** unauthenticated protocol master rejected where SA/TLS is required. **Ext. tools:** Wireshark (DNP3-SA / TLS); DNP3/Modbus test client (isolated); Nmap.	Secured protocol peers authenticate (DNP3-SA/TLS); unauthenticated masters rejected on secured links.	
SR/CR 1.3	Account management	RBAC roles least privilege; central auth via **LDAP/RADIUS** where used; password policy and certificate lifecycle managed; remove defaults. **Ext. tools:** acSELerator RTAC (roles/policy); openssl (cert validity).	Named least-priv roles; central auth; authenticators managed; no defaults.	
SR/CR 1.4	Identifier management	In **acSELerator RTAC (SEL-5033)** › Security › Accounts, confirm each user has a unique identifier; confirm a unique device identity (hostname/IP) and unique client/server IDs for each protocol map; no reuse. **Ext. tools:** acSELerator RTAC (account + tag/map review).	Unique user and device identifiers; no reuse.	
SR/CR 1.5	Authenticator management	Confirm authenticators (passwords, keys, certs) are managed, protected and rotated; defaults changed. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Authenticator management verified individually.	
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password auth	Confirm the RTAC password policy (length/complexity/expiry) or the upstream LDAP/RADIUS policy. **Ext. tools:** Policy review; attempt weak password -> rejected.	Strong password policy enforced.	
SR/CR 1.8	PKI certificates	The RTAC uses X.509 certificates for HTTPS / IEC 62351 / TLS; in Security › Certificates upload a CA-signed certificate and confirm validity/expiry and chain (replace the default self-signed). **Ext. tools:** Browser cert view; openssl x509.	CA-signed certificate installed and valid; default replaced.	
SR/CR 1.9	Strength of public key auth	Confirm TLS / SSH and DNP3-SA / IEC 62351 use strong keys and algorithms (>=2048 RSA / ECC, SHA-256+); no weak or expired credentials. **Ext. tools:** testssl.sh (:443); ssh-audit.	Strong key/cert crypto on all secured protocols.	
SR/CR 1.10	Authenticator feedback	Confirm acSELerator RTAC and the web/SSH login mask password entry (no cleartext echo). **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Confirm account lockout after repeated failures (RTAC setting or upstream RADIUS/LDAP). **Test:** exceed the threshold -> lockout + logged event. **Ext. tools:** Repeated invalid logins (authorized); audit-log review.	Lockout on excess failures; logged.	
SR/CR 1.12	System use notification	Set the approved login/use notification in the RTAC security settings (web / SSH login banner) so it is presented before access. **Ext. tools:** SSH/web login (banner check).	Approved use notification presented before access.	
SR 1.13	Access via untrusted networks	Segment the RTAC; expose only TLS engineering/web off-segment; disable unused protocols/SSH; brokered remote access. **Ext. tools:** Nmap by segment; firewall review.	Only secure channels reachable off-segment; unauthenticated protocols contained.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	Confirm RBAC roles enforce least privilege for view vs configure vs security/firmware actions. **Test:** a view-only user cannot change configuration or protocols. **Ext. tools:** acSELerator RTAC (role review); attempt privileged action as view-only user.	Least privilege enforced by role; privileged actions denied.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use Control for Portable and Mobile Devices	**N/A.** Device does not host portable/mobile-media use; USB/portable-device use is controlled at the engineering host (EWS).	N/A - justification recorded (not assessed as a control).	N/A
SR/EDR 2.4	Mobile code	No general-purpose mobile code runs on the RTAC; confirm only SEL-signed firmware and the compiled IEC 61131 project logic execute; no untrusted scripts/apps are loadable on Blueframe. **Ext. tools:** acSELerator RTAC (firmware / project review).	Only trusted signed code runs; no untrusted mobile code.	EDR-specific.
SR/CR 2.5	Session lock	Confirm web/engineering session inactivity timeout re-prompts for sign-in. **Ext. tools:** Manual idle test.	Idle sessions time out.	
SR/CR 2.6	Remote session termination	Confirm sessions can be terminated (logout/disconnect), the **session inactivity timeout** closes idle SSH/web sessions, and account lockout applies after failed logons. **Ext. tools:** acSELerator RTAC; SSH/web (timeout/lockout test).	Remote sessions terminable on demand and on inactivity.	
SR/CR 2.7	Concurrent session control	Confirm concurrent management sessions are limited or monitored; the RTAC bounds simultaneous engineering/web/SSH connections. **Ext. tools:** acSELerator RTAC (active connections); Wireshark.	Concurrent sessions limited or monitored.	
SR/CR 2.8	Auditable events	Review the RTAC **audit log / SER** (Sequential Events Recorder) for logins, config changes, and security events with user attribution; enable **syslog** offload. **Test:** a config change is logged with user + time. **Ext. tools:** acSELerator RTAC (SER/audit); syslog listener.	Security events logged with user + time; offloaded to syslog; changes attributable.	
SR/CR 2.9	Audit storage capacity	The RTAC log / Sequence-of-Events store is finite; enable **Syslog** forwarding to the SIEM for retention and confirm sizing/threshold. **Ext. tools:** acSELerator RTAC (syslog config); SIEM retention.	Events offloaded and retained; alert before capacity.	
SR/CR 2.10	Response to audit processing failures	Confirm the SIEM/syslog collector alerts on forwarding failure; the RTAC continues logging locally so events are not silently lost. **Ext. tools:** SIEM alerting configuration.	Audit-failure alerting defined; local logging continues.	
SR/CR 2.11	Timestamps	Confirm time sync (NTP / IRIG-B / IEEE 1588) and time-source integrity; SER timestamps accurate. **Ext. tools:** Wireshark (NTP); acSELerator time-source review.	Accurate synced time; SER timestamps consistent.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
EDR 2.13	Physical diagnostic & test interfaces	Control the RTAC physical ports (USB / SD / console / front-panel service); keep the unit in a locked panel and disable/seal service ports when not in use. **Ext. tools:** Physical inspection (port covers/seals).	Physical/diagnostic interfaces controlled and sealed.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	Enable **TLS** for web/engineering; **DNP3-SA**/IEC 62351 for control protocols; replace default certificate with a CA-signed cert; confirm secured links are encrypted/authenticated. **Ext. tools:** testssl.sh / sslscan (:443); Wireshark (TLS / DNP3-SA); openssl (cert chain).	Secured comms TLS/SA-protected; CA-signed cert installed.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/EDR 3.2	Protection from malicious code	The RTAC uses **signed firmware** + secure boot; load only SEL-signed firmware; protect the project/config baseline; verify integrity on update. **Ext. tools:** Firmware signature verify during update; SEL checksum.	Only signed firmware runs; config integrity protected.	
SR/CR 3.3	Security functionality verification	After any change, re-verify security settings against the baseline and export/compare the RTAC settings (.rtacx) to the approved baseline; confirm disabled services stayed off. **Ext. tools:** acSELerator RTAC (settings compare); Nmap.	Security settings match the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Confirm software & information (config/program) integrity; unauthorized change prevented/detected. **Steps:** for this product this is assessed with the same evidence as **SR/EDR 3.2** above (shared steps); confirm this requirement individually and adjudicate it separately.	Software & information integrity verified individually.	
SR/CR 3.5	Input validation	Confirm the RTAC tolerates malformed DNP3 / Modbus / IEC 61850 frames without faulting or loss of control. **ISOLATED only:** fuzz the protocol interfaces on a representative unit and watch logic/comms health. **Ext. tools:** Protocol fuzzer / traffic generator (ISOLATED); Wireshark.	No crash or loss of control on malformed input.	Do NOT fuzz production.
SR/CR 3.6	Deterministic output	Verify configured fail-safe behavior for controlled outputs — hold-last-state vs safe-state on comm loss or logic fault — so outputs assume a defined safe state. **Ext. tools:** acSELerator RTAC (I/O fail-state / logic review).	Outputs go to a defined/fail-safe state on fault or comm loss.	
SR/CR 3.7	Error handling	Confirm the RTAC handles faults/errors gracefully (diagnostics, watchdog, no loss of control or info leakage). **Ext. tools:** acSELerator RTAC (diagnostics review).	Graceful fault handling; no unsafe state or info leak.	
SR/CR 3.8	Session integrity	TLS/SSH and DNP3-SA / IEC 62351 protect sessions against replay/hijack; confirm secured channels are in use and old sessions cannot be replayed. **Ext. tools:** Wireshark (session inspection).	Sessions integrity-protected on secured channels.	
SR/CR 3.9	Protection of audit information	Protect the SOE/log and Syslog transport, and restrict roles so logs cannot be cleared/altered by unauthorized users. **Ext. tools:** acSELerator RTAC (role review); SIEM access review.	Audit records protected from unauthorized read/modify/delete.	
EDR 3.10	Support for updates	Signed firmware update via acSELerator with rollback; RTAC in a locked panel; control front/USB interfaces; SEL tamper-evident hardware. **Ext. tools:** acSELerator update (authorized); physical inspection.	Signed updatable with rollback; physical access controlled.	EDR-specific.
EDR 3.11	Physical tamper resistance & detection	Confirm physical tamper resistance/detection (device requirement). **Steps:** for this product this is assessed with the same evidence as **EDR 3.10** above (shared steps); confirm this requirement individually and adjudicate it separately.	Physical tamper resistance & detection verified individually.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	The RTAC accepts only SEL-signed firmware (product-supplier root of trust); confirm the signing chain is intact and unsigned/altered firmware is rejected at load. **Ext. tools:** acSELerator RTAC (firmware signature verify).	Supplier signing root intact; unsigned firmware rejected.	EDR-specific.
EDR 3.13	Provisioning asset-owner roots of trust	Upload the asset owner's CA-signed certificate for TLS / IEC 62351 and confirm the asset owner can provision/manage its own certificates and trust anchors. **Ext. tools:** acSELerator RTAC (certificate upload/verify).	Asset-owner certificate provisioning supported and verified.	EDR-specific.
EDR 3.14	Integrity of the boot process	Confirm the RTAC validates signed-firmware / secure-boot integrity before execution; no unsigned/tampered firmware runs. Capture firmware version + signature status. **Ext. tools:** acSELerator RTAC (firmware version/signature).	Firmware integrity validated before execution; only signed firmware boots.	EDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission or repurpose, reset/reimage the RTAC to clear the project, accounts, certificates, and logs, and sanitize/destroy any SD/USB media so credentials and configuration are not recoverable. **Ext. tools:** acSELerator RTAC (reset/reimage); media sanitize.	Sensitive data purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	Confirm TLS 1.2/1.3 + strong ciphers on web/engineering; DNP3-SA keys managed; disable weak protocol versions; replace default cert. **Ext. tools:** testssl.sh / sslyze (:443); openssl.	Modern TLS + strong ciphers; keys managed; default cert replaced.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation	RTAC bridges field protocol networks and the supervisory network — confirm segmentation, that only required flows cross, and (as a host) that any hosted apps/containers are isolated. **Ext. tools:** Nmap by zone (443/20000/502/102); firewall review.	Field and supervisory networks separated; only approved flows.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General Purpose Person-to-Person Communication Restrictions	**N/A.** Embedded device has no general-purpose person-to-person communications (email/IM/web).	N/A - justification recorded (not assessed as a control).	N/A
SR 5.4	Application Partitioning	**N/A.** Single-purpose device; no separable applications to partition (handled at the host/SCADA layer).	N/A - justification recorded (not assessed as a control).	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility	Confirm audit/SER logs are readable/exportable and **syslog** ships events to the SIEM; passive monitoring of the segment. **Ext. tools:** Syslog listener (`nc -lu 514`); passive OT monitor.	Events accessible/exportable; forwarded to SIEM; monitoring active.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial of service protection	Disable unused protocols/services to shrink surface; confirm the RTAC keeps executing logic/comms under load; monitor CPU/memory. **Ext. tools:** Traffic generator (ISOLATED); acSELerator diagnostics.	RTAC keeps controlling under load; resources bounded; surface minimized.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.2	Resource management	Confirm resource management — resources are bounded; no exhaustion-based loss of function. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Resource management verified individually.	
SR/CR 7.3	Control system backup	Back up the acSELerator RTAC project + device configuration + certificates; test restore on a spare RTAC. **Ext. tools:** `sha256sum` of project export; acSELerator restore (lab).	Verified project/config backup; restore tested.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Verify settings vs the SEL hardening baseline; **disable unused protocols/services** (SSH, unused DNP/Modbus/61850), change default ports, and disable the web interface where not needed. **Ext. tools:** Nmap (open protocols/ports); acSELerator settings review.	Only required protocols/services enabled; settings match baseline.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Capture model (SEL-3505), RTAC firmware, and enabled protocols for the inventory. **Ext. tools:** acSELerator RTAC; ReadOnlyEnum.	Complete model/firmware/app/protocol inventory captured.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
acSELerator RTAC (SEL-5033)	Native config, RBAC, SER/audit review (all)	Open the project read-only; review users/roles, protocol/TLS settings, certificates, and the SER/audit log.	Read-only project review; TLS.
Project/config backup + sha256sum	Baseline, drift, recovery (3.4, 7.3)	Export the project/config; hash to detect drift; restore on a lab RTAC.	Backup may hold secrets — protect it.
testssl.sh / sslscan / sslyze	TLS/cipher/cert strength (3.1, 4.3)	`testssl.sh https://:443`; confirm TLS only, strong ciphers, CA-signed cert.	Read-only/safe.
openssl	Certificate inspection (1.5, 3.1, 4.3)	`openssl s_client -connect :443 | openssl x509 -noout -issuer -dates`; confirm chain/validity.	Read-only.
Nmap / PortQry	Protocol/port exposure & segmentation (1.13, 5.x, 7.7)	`nmap -sT -p 443,22,20000,502,102,514 -T2` ; scan by zone; confirm unused protocols closed.	Tune timing on production.
Wireshark / tcpdump	Comm integrity (1.2, 3.1)	SPAN/tap; confirm TLS on 443 and DNP3-SA/IEC 62351 on control links; no cleartext creds.	Passive; SPAN/tap only.
DNP3 / Modbus test client	Unauthenticated-protocol exposure (1.2)	Read-only queries to confirm which protocols answer without SA/TLS; verify segmentation compensates.	Read-only on production.
Syslog listener (nc / rsyslog)	Log offload verification (2.8, 6.x)	Stand up a listener; trigger a login/config event; confirm the RTAC forwards it to the SIEM.	Coordinate with SIEM team.
Traffic generator	DoS resilience (7.1)	High-rate protocol testing while watching logic/comms continue.	ISOLATED/non-production; authorization.
ReadOnlyEnum	Host/network/protocol enumeration (7.8)	Enumerate services/ports read-only.	Read-only.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.